

Table of Contents

Executive Summary	iv
1 Purpose.....	1
2 Introduction	2
2.1 Applicability	4
2.2 Considerations, Other Requirements, and Flexibilities	5
2.3 A Few Limitations.....	5
2.4 How to Use this Suite of SPs	5
2.5 Change History	6
2.5.1 SP 800-63-1	6
2.5.2 SP 800-63-2	6
2.5.3 SP 800-63-3	6
3 Definitions and Abbreviations	8
4 Digital Identity Model	9
4.1 Overview.....	9
4.2 Enrollment and Identity Proofing	12
4.3 Authentication and Lifecycle Management	12
4.3.1 Authenticators	12
4.3.2 Credentials	14
4.3.3 Authentication Process.....	14
4.4 Federation and Assertions	14
4.4.1 Assertions.....	15
4.4.2 Relying Parties	16
5 Digital Identity Risk Management	17
5.1 Overview.....	17
5.2 Assurance Levels.....	18
5.3 Risk and Impacts	19
5.3.1 Business Process vs. Online Transaction	20
5.3.2 Impacts per Category	21
5.4 Risk Acceptance and Compensating Controls.....	22
5.5 Digital Identity Acceptance Statement	23
5.6 Migrating Identities.....	23

6	Selecting Assurance Levels.....	25
6.1	Selecting IAL.....	26
6.2	Selecting AAL	29
6.3	Selecting FAL.....	31
6.4	Combining xALs.....	33
7	Federation Considerations.....	35
8	References.....	36
8.1	General References.....	36
8.2	Standards	37
8.3	NIST Special Publications.....	37
8.4	Federal Information Processing Standards.....	37

List of Appendices

Appendix A— Definitions and Abbreviations	39
A.1 Definitions	39
A.2 Abbreviations	58

List of Figures

Figure 4-1 Digital Identity Model.....	10
Figure 6-1 Selecting IAL.....	27
Figure 6-2 Selecting AAL	30
Figure 6-3 Selecting FAL.....	32

List of Tables

Table 2-1 Normative and Informative Sections of SP 800-63-3	4
Table 5-1 Identity Assurance Levels	18
Table 5-2 Authenticator Assurance Levels.....	19
Table 5-3 Federation Assurance Levels.....	19
Table 6-1 Maximum Potential Impacts for Each Assurance Level.....	25
Table 6-2 Acceptable Combinations of IAL and AAL.....	34

Errata

This table contains changes that have been incorporated into Special Publication 800-63-3. Errata updates can include corrections, clarifications, or other minor changes in the publication that are either editorial or substantive in nature.

Date	Type	Change	Location
2017-12-01	Editorial	Removed the term ‘cryptographic’ from the AAL3 description.	Executive Summary
	Editorial	Updated reference to Risk Management Framework	§5
	Editorial	Fixed verbiage in xAL flowcharts	Figures 6-1, 6-2, and 6-3
	Editorial	Added NISTIR 8062 as a reference	§8.1
	Editorial	Added definitions for disassociability, manageability, processing, and predictability	Appendix A
2020-03-02	Editorial	Fixed wording of FAL3 definition	§5.2
	Substantive	Clarified flowcharts for xAL selection	Figures 6-1, 6-2, and 6-3
	Substantive	Added definition for Authorization Component	Appendix A
	Editorial	Removed extraneous definition of Protected Session	Appendix A

1 Purpose

This section is informative.

This recommendation and its companion volumes, [Special Publication \(SP\) 800-63A](#), [SP 800-63B](#), and [SP 800-63C](#), provide technical guidelines to agencies for the implementation of digital authentication.

2 Introduction

This section is informative.

Digital identity is the unique representation of a subject engaged in an online transaction. A digital identity is always unique in the context of a digital service, but does not necessarily need to uniquely identify the subject in all contexts. In other words, accessing a digital service may not mean that the subject's real-life identity is known. Identity proofing establishes that a subject is who they claim to be. Digital authentication is the process of determining the validity of one or more authenticators used to claim a digital identity. Authentication establishes that a subject attempting to access a digital service is in control of the technologies used to authenticate. Successful authentication provides reasonable risk-based assurances that the subject accessing the service today is the same as that which previously accessed the service. Digital identity presents a technical challenge because this process often involves proofing individuals over an open network, and typically involves the authentication of individual subjects over an open network to access digital government services. There are multiple opportunities for impersonation and other attacks that fraudulently claim another subject's digital identity.

This recommendation provides agencies with technical guidelines for digital authentication of subjects to federal systems over a network. This recommendation also provides guidelines for credential service providers (CSPs), verifiers, and relying parties (RPs).

These guidelines describe the risk management processes for selecting appropriate digital identity services and the details for implementing identity assurance, authenticator assurance, and federation assurance levels based on risk. Risk assessment guidance in these guidelines supplements the *NIST Risk Management Framework* [[NIST RMF](#)] and its component special publications. This guideline does not establish additional risk management processes for agencies. Rather, requirements contained herein provide specific guidance related to digital identity risk while executing all relevant RMF lifecycle phases.

Digital authentication supports privacy protection by mitigating risks of unauthorized access to individuals' information. At the same time, because identity proofing, authentication, authorization, and federation involve the processing of individuals' information, these functions can also create privacy risks. These guidelines therefore include privacy requirements and considerations to help mitigate potential associated privacy risks.

These guidelines support the mitigation of the negative impacts induced by an authentication error by separating the individual elements of identity assurance into discrete, component parts. For non-federated systems, agencies will select two components, referred to as *Identity Assurance Level (IAL)* and *Authenticator Assurance Level (AAL)*. For federated systems, a third component, *Federation Assurance Level (FAL)*, is included. [Section 5, Digital Identity Risk Management](#) provides details on the risk assessment process. [Section 6, Selecting Assurance Levels](#) combines the results of the risk assessment with additional context to support agency selection of the appropriate IAL, AAL, and FAL combinations based on risk.

These guidelines do not consider nor result in a composite level of assurance (LOA) in the context of a single ordinal that drives implementation-specific requirements. Rather, by combining appropriate risk management for business, security, and privacy side-by-side with mission need, agencies will select IAL, AAL, and FAL as distinct options. Specifically, this document does not recognize the four LOA model previously used by federal agencies and described in OMB [M-04-04](#), instead requiring agencies to individually select levels corresponding to each function being performed. While many systems will have the same numerical level for each IAL, AAL, and FAL, this is not a requirement, and agencies should not assume they will be the same in any given system or application.

The components of identity assurance detailed in these guidelines are as follows:

- IAL refers to the identity proofing process.
- AAL refers to the authentication process.
- FAL refers to the assertion protocol used in a federated environment to communicate authentication and attribute information (if applicable) to an RP.

As such, SP 800-63 is organized as a suite of volumes as follows:

SP 800-63 Digital Identity Guidelines: Provides the risk assessment methodology and an overview of general identity frameworks, using authenticators, credentials, and assertions together in a digital system, and a risk-based process of selecting assurance levels. *SP 800-63 contains both normative and informative material.*

SP 800-63A Enrollment and Identity Proofing: Addresses how applicants can prove their identities and become enrolled as valid subjects within an identity system. It provides requirements for processes by which applicants can both proof and enroll at one of three different levels of risk mitigation in both remote and physically-present scenarios. *SP 800-63A contains both normative and informative material.*

SP 800-63B Authentication and Lifecycle Management: Addresses how an individual can securely authenticate to a CSP to access a digital service or set of digital services. This volume also describes the process of binding an authenticator to an identity. *SP 800-63B contains both normative and informative material.*

SP 800-63C Federation and Assertions: Provides requirements on the use of federated identity architectures and assertions to convey the results of authentication processes and relevant identity information to an agency application. Furthermore, this volume offers privacy-enhancing techniques to share information about a valid, authenticated subject, and describes methods that allow for strong multi-factor authentication (MFA) while the subject remains pseudonymous to the digital service. *SP 800-63C contains both normative and informative material.*

NIST anticipates that individual volumes in these guidelines will be revised asynchronously. At any time, the most recent revision of each should be used (e.g., if at a time in the future SP 800-63A-1 and SP 800-63B-2 are the most recent revisions of each volume, they should be used together even though the revision numbers do not match). To minimize the risk of compatibility

errors, a reference to the base document (i.e., SP 800-63 rather than SP 800-63-3) always refers to the current version of the document.

The following table states which sections of this volume are normative and which are informative:

Table 2-1 Normative and Informative Sections of SP 800-63-3

Section Name	Normative/Informative
1. Purpose	Informative
2. Introduction	Informative
3. Definitions and Abbreviations	Informative
4. Digital Identity Model	Informative
5. Digital Identity Risk Management	Normative
6. Selecting Assurance Levels	Normative
7. Federation Considerations	Informative
8. References	Informative

2.1 Applicability

Not all digital services require authentication or identity proofing; however, this guidance applies to all such transactions for which digital identity or authentication are required, regardless of the constituency (e.g. citizens, business partners, government entities).

Transactions not covered by this guidance include those associated with national security systems as defined in 44 U.S.C. § 3542(b)(2). Private sector organizations and state, local, and tribal governments whose digital processes require varying levels of assurance may consider the use of these standards where appropriate.

These guidelines primarily focus on agency services that interact with the non-federal workforce, such as citizens accessing benefits or private sector partners accessing information sharing collaboration spaces. However, it also applies to internal agency systems accessed by employees and contractors. These users are expected to hold a valid government-issued credential, primarily the Personal Identity Verification (PIV) card or a derived PIV. Therefore [SP 800-63A](#) and [SP 800-63B](#) are secondary to the requirements of [FIPS 201](#) and its corresponding set of special publications and agency-specific instructions. However, [SP 800-63C](#) and the risk-based selection of an appropriate FAL applies, regardless of the credential type the internal user holds. FAL

selection provides agencies guidance and flexibility in how to PIV-enable their applications based on system risk.

2.2 Considerations, Other Requirements, and Flexibilities

Agencies may employ other risk mitigation measures and compensating controls not specified herein. Agencies need to ensure that any mitigations and compensating controls do not degrade the selected assurance level's intended security and privacy protections. Agencies may consider partitioning the functionality of a digital service to allow less sensitive functions to be available at a lower level of authentication and identity assurance.

Agencies may determine based on their risk analysis that additional measures are appropriate in certain contexts. In particular, privacy requirements and legal risks may lead agencies to determine that additional authentication measures or other process safeguards are appropriate. When developing digital authentication processes and systems, agencies should consult *OMB Guidance for Implementing the Privacy Provisions of the E-Government Act of 2002* [[M-03-22](#)]. See the *Use of Electronic Signatures in Federal Organization Transactions* [[ESIG](#)] for additional information on legal risks, especially those related to the need to 1) satisfy legal standards of proof and 2) prevent repudiation.

Additionally, federal agencies implementing these guidelines should adhere to their statutory responsibilities under the Federal Information Security Modernization Act (FISMA) of 2014, 44 U.S.C. § 3551 et seq., Public Law (P.L.) 113-283 [[FISMA](#)], and related NIST standards and guidelines. FISMA directs federal agencies to develop, document, and implement agency-wide programs to provide security for the information and systems that support the agency's operations and assets. This includes the security authorization and accreditation (SA&A) of IT systems that support digital authentication. NIST recommends that non-federal entities implementing these guidelines follow equivalent standards to ensure the secure operations of their digital systems.

2.3 A Few Limitations

These technical guidelines do not address the authentication of subjects for physical access (e.g., to buildings), though some authenticators used for digital access may also be used for physical access authentication. Additionally, this revision of these guidelines does not explicitly address device identity, often referred to as machine-to-machine (such as router-to-router) authentication or interconnected devices, commonly referred to as the internet of things (IoT). That said, these guidelines are written to refer to generic subjects wherever possible to leave open the possibility for applicability to devices. Also excluded are specific requirements for issuing authenticators to devices when they are used in authentication protocols with people.

2.4 How to Use this Suite of SPs

The business model, marketplace, and composition of how identity services are delivered has drastically changed since the first version of SP 800-63 was released. Notably, CSPs can be componentized and comprised of multiple independently-operated and owned business entities. Furthermore, there may be a significant security benefit to using strong authenticators even if no

identity proofing is required. Therefore, in this revision, a suite of SPs under the 800-63 moniker has been created to facilitate these new models and make it easy to access the specific requirements for the function an entity may serve under the overall digital identity model.

2.5 Change History

2.5.1 SP 800-63-1

NIST SP 800-63-1 updated NIST SP 800-63 to reflect current authenticator (then referred to as “token”) technologies and restructured it to provide a better understanding of the digital identity architectural model used here. Additional (minimum) technical requirements were specified for the CSP, protocols used to transport authentication information, and assertions if implemented within the digital identity model.

2.5.2 SP 800-63-2

NIST SP 800-63-2 was a limited update of SP 800-63-1 and substantive changes were made only in Section 5, *Registration and Issuance Processes*. The substantive changes in the revised draft were intended to facilitate the use of professional credentials in the identity proofing process, and to reduce the need to send postal mail to an address of record to issue credentials for level 3 remote registration. Other changes to Section 5 were minor explanations and clarifications.

2.5.3 SP 800-63-3

NIST SP 800-63-3 is a substantial update and restructuring of SP 800-63-2. SP 800-63-3 introduces individual components of digital authentication assurance — AAL, IAL, and FAL — to support the growing need for independent treatment of authentication strength and confidence in an individual’s claimed identity (e.g., in strong pseudonymous authentication). A risk assessment methodology and its application to IAL, AAL, and FAL has been included in this guideline. It also moves the whole of digital identity guidance covered under SP 800-63 from a single document describing authentication to a suite of four documents (to separately address the individual components mentioned above) of which SP 800-63-3 is the top-level document.

Other areas updated in 800-63-3 include:

- Renamed to “Digital Identity Guidelines” to properly represent the scope includes identity proofing and federation, and to support expanding the scope to include device identity, or machine-to-machine authentication in future revisions.
- Terminology changes, including the use of authenticator in place of token to avoid conflicting use of the word token in assertion technologies.
- Updates to authentication and assertion requirements to reflect advances in both security technology and threats.
- Requirements on the storage of long-term secrets by verifiers.
- Restructured identity proofing model.
- Updated requirements regarding remote identity proofing.
- Clarification on the use of independent channels and devices as “something you have”.